CODE AUDIT

光学交互实验室 AI v6.4.26 · 代码审计报告

11,902 行 / 8.37 MB / 16 个脚本块 · 语法校验 16/16 通过

P0 × 2 | P1 × 7 | P2 × 5 | P3 × 2 | ✅ 保留设计 × 10

01 结论摘要

总体判断：工程质量在平均线以上，问题集中在「体积失控」与「复制粘贴漂移」

有全局异常兜底、启动超时、三语 i18n、无障碍模块、iframe 渲染自愈、API Key 脱敏与退出守卫——这些是多数教学单文件作品完全没有的。主要问题不在"写得对不对"，而在**单文件体积失控**与**同源漂移**。

一句话结论

功能架构是好的。`v6.4.27` 建议只做一次**「消肿 + 去漂移」专项**：把 8.37 MB 压到 5 MB 以内、把两个 three.js 构建统一；其余按 P1 清单分批清账，**无需大改架构**。

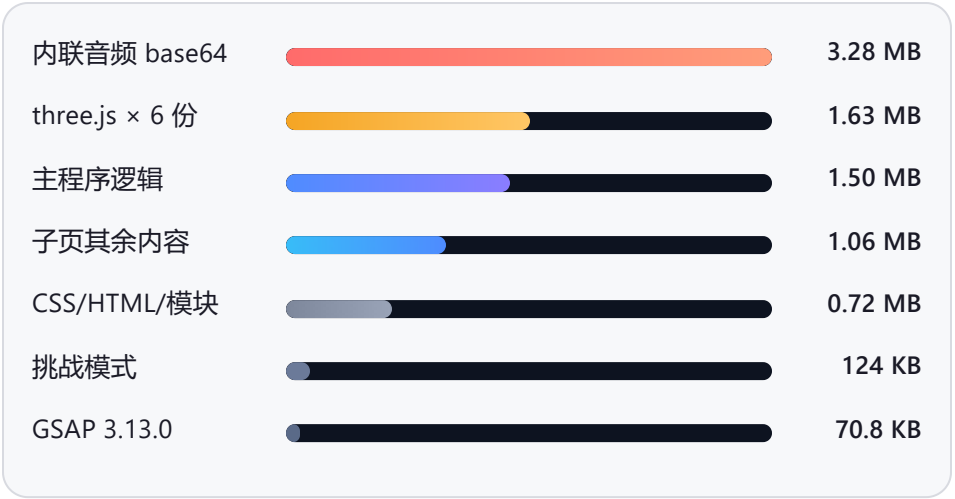
审查方式与可信度

- 静态结构剖析：逐块切分 16 个真实 `<script>` + 14 个 `<style>`
- 指纹比对：对内嵌压缩库做 MD5，判定重复与版本漂移
- 关键面量扫描：密钥、CSP、sandbox、postMessage、innerHTML、catch 覆盖率
- `node --check` 逐块语法校验 → **16/16 通过**，无语法错误、无裸 `</script>` 提前截断

级别	数量	主题
P0	2	three.js 同页混用两个构建；1.39 MB 逐字节重复
P1	7	Key 明文存储、空 catch 静默、innerHTML 转义不彻底、E2E 钩子进生产、postMessage 源不校验、无 CSP/sandbox、监听器与 blob 泄漏
P2	5	全局作用域名污染、console 噪音、版本注释堆积、风格断层、交付目录卫生
P3	2	注释与实现不符、可删的兼容别名
保留	10	见第五节，不要为了重构而重构掉

02 体积构成剖析

8.37 MB 的真实去向——这是 P0 的量化依据。



动作	省下	风险
5 份重复 three.js 合并为共享 1 份	**1.08 MB**	中，需改 5 个子页加载顺序
音频降码率（24→16 kbps 单声道）	**0.8–1.2 MB**	低，人声教学足够
音频改按需注入	首屏 −3.28 MB	中，需改 `_audioBlobUrl`
6 个子页共用公共外壳代码	0.3–0.5 MB	中

预期结果

8.37 MB → **5.0 MB 左右**（保守），激进可到 **4.5 MB**。对"U 盘拷到教室电脑双击打开"和"手机扫码预览"这两个真实使用场景，这是最直接的体验改善。

03 P0 问题 · 建议 v6.4.27 必修

P0-1 · 同一页面混用两个不同的 three.js 构建

对 6 个内嵌子页各自抽出的压缩库做 MD5：

```
336f961d4c  277.6KB/份 ×5
   → __ECL_HTML__ / __S3D_PINHOLE__ / __S3D_REFL__
     __S3D_LENS__ / __S3D_MIRROR__
a688d76480  279.9KB/份 ×1
   → __S3D_SHADOW__          ← 不同的构建
```

`__S3D_SHADOW__` 中 `THREE` 标识出现 172 次，其余 5 份均为 177 次；`WebGLRenderer` 出现 36 次 vs 35 次。**这不是同一份文件。**

影响

- 五个 3D 场景（反射 / 凸透镜 / 平面镜 / 小孔 / 影子）中 4 个基于构建 A、1 个基于构建 B，行为差异不可控——`OrbitControls` 手感、色彩管理、阴影贴图默认值在不同 three.js 构建间会有可感知差别。
- 升级 three.js 必须改 **6 处**，且第 6 处是"另一版本"，极易漏改，形成长期漂移。
- 尾块注释（L11538）声称"自带的 three.js r147"，与"存在两个构建"这一事实矛盾——注释需修正，也说明版本已经脱管。

建议

确定唯一 three.js 构建，重新导出 6 个子页；在文件顶部加一行版本常量 `THREE_BUILD = 'r147'`，内嵌页加载后 `console.assert` 校验 `THREE.REVISION`，让漂移在测试期就暴露。

P0-2 · 1.39 MB 逐字节重复

5 份完全相同的 277.6 KB 库 = **1,387.8 KB**，占全文件 **16.6%**。
根因：这 5 个子页是从同一模板"复制粘贴 + 局部改写"生成的（公共前缀 0%，但库部分逐字节一致）。

建议（按实施成本排序）

- **方案 A（推荐，改动最小）**：父页只保留 1 份 three.js（作为 `window.__THREE_SRC__` 字符串），子页 srcdoc 里把库源码替换为从父页 blob URL 加载——一次性改 5 处模板，省 1.08 MB。
- **方案 B**：音频改外部资源，接受"多文件"。**不推荐**——用户已明确要"单文件拷了就能用"。
- **方案 C**：接受现状，但把 three.js 抽成 `window.__THREE__` 常量集中存放。省不下体积，但能防漂移。

04 P1 问题 · 建议 v6.5 清账

P1-1 API Key 明文存 localStorage，baseUrl 无白名单

`ai_optics_v1_cfg`、`ai_optics_v1_judge` 两个键明文存 `apikey`；配置项含自定义 `baseUrl`（L8034），Key 可被发往任意地址。

已有缓解（值得肯定）

`escapeKey()` 脱敏（前 4 + 后 4）、`detectLocalKeys()` 检测、`armApiKeyClearOnExit()` 在 `beforeunload/pagehide` 挂守卫并提供"全部保留 / 仅清判卷 / 全部清除"三选项。

残留风险：同机其他进程 / 浏览器扩展 / 后续打开同一 `file://` 的页面可读走明文 Key。

建议：① 自定义 baseUrl 旁提示"Key 将发送到该地址，请确认可信"；② 密码框加 `autocomplete="off"`；③ 长期可评估 WebCrypto 派生密钥加密（教育场景非必须）。

P1-2 62 处空 `catch(e){}` 静默吞异常

与"V4.9.1 可诊断"的设计目标直接冲突——真正出错时，兜底模块什么都收不到。

建议：统一改成 `catch(e){ console.warn('[ctx]', e && e.message); }`。`localStorage` 相关读写可保留静默（隐私模式），其余全部出声。

P1-3 innerHTML 转义不彻底

102 处 `.innerHTML =`；已定位至少 1 处未走转义的拼接：

```
// L3796
el.innerHTML = '<div class="rpt-concl">' +
  '<div class="claim">' + c.claim + '</div>' + ...
```

项目已在 **L2958–L2968** 收敛出**全局唯一** `escHtml()`（注释自述"原 kmapEsc / escapeHtml / escHtml 三份重复实现已全部收敛"），但调用不彻底。

建议：凡拼 **AI 返回内容 / 学生姓名 / 学号 / 用户输入问题** 的位置，一律过 `escHtml()`。特别复查"AI 判卷结果回显"与"错题诊断报告"两条链路。

P1-4 `runE2E` 自测钩子留在生产代码

L5687 定义了 `function runE2E(...)`，在正式交付文件中。

建议：迁到独立的 `e2e_v6426.py` 侧（已有此机制），生产文件里删掉；若需保留，必须由 URL 参数或 `localStorage` 开关显式启用，并确保默认不可达。

P1-5 postMessage 全用 `'*'` 目标源，接收端不校验来源

7 处发送、6 处监听。监听端**只校验消息形状不校验来源**：

```
// L11484 等
window.addEventListener('message', function (e) {
  var m = e && e.data;
  if (!m || typeof m !== 'object' || typeof m.t !== 'string'
  if (m.t === 's3d:param') {
    if (typeof m.name !== 'string' || !ALLOWED.test(m.name))
    if (typeof m.value !== 'number' || !isFinite(m.value)) r
```

代码注释已说明取舍："离线 `file://` 下 origin 为 null，故不做 origin 校验，只严格校验消息形状"。这个理由**成立**，且白名单 + 数值校验把危害压得很低——但仍有更优解。

建议：改为校验 `e.source === 目标 iframe.contentWindow`（父页端）或 `e.source === window.parent`（子页端）。该判据在 `file://` 下同样有效，且精确到"就是我这个对端"，比 origin 更强。当前方案属"能跑但次优"，是可修复的欠债。

P1-6 无 CSP / 无 iframe sandbox / 外链无 SRI

`Content-Security-Policy` 0 处、`sandbox=` 0 处、`integrity=` 0 处；有 6 处外链 CDN 引用。

`file://` 单文件 + 全内联的设计下，CSP 价值有限，**可以接受不加**。但 5 个 3D 子页是自己的内容，加 `sandbox="allow-scripts allow-same-origin"` 成本极低（一行），能顺手隔离子页异常。

P1-7 监听器 137 : 0 不卸载；11 个 blob URL 永不回收

- `addEventListener` 137 处，`removeEventListener` **0** 处，全部匿名 → 结构上无法卸载。代码里有 `reclaim()/remount` 自愈路径（L11427 等），反复挂载时缺乏对称清理手段。
- `_audioBlobUrl()`（L4436–L4446）创建的 blob URL 存入 `_audioCache` 后**永不** `revokeObjectURL`；11 段全播一遍常驻 ~2.4 MB blob，叠加源码里无法释放的 3.28 MB base64 字符串常量，常驻内存约 **5.7 MB**。

建议：① 长生命周期全局监听改用 `AbortController` + `signal`（现代浏览器全支持，能批量卸载）；② 页面 `pagehide` 时遍历 `_audioCache` 做一次 `revokeObjectURL`。

05 已验证为良好、建议保留

这些是作品真正的技术亮点，**不要为了重构而重构掉。**

- **V4.9.1 全局健壮性兜底**（L17–L184）：捕获 `error` / `unhandledrejection` + 15 秒启动超时 + 固定浮层 + 「复制错误信息」。资源类失败只记日志不弹层、启动成功后偶发异常不打断使用——分层判断很成熟。
- **切 tab 停 3D 渲染省电**：父页发 `ecl:active` / `s3d:active` 控制子页渲染循环启停。
- **懒挂载 srcdoc**：首次进入某场景才 `setAttribute('srcdoc')`，避免 6 个 WebGL 上下文同时创建。
- **iframe 渲染上下文丢失自愈**：`ecl:lost` → `reclaim()` → 最多重挂 2 次。
- `s3d:ready` **补发机制**（L11831）：解决"remount 后初始 init/active 消息发进正在重载的 iframe 而丢失"的竞态——很有经验的修法。
- **API Key 脱敏 + 退出守卫三选项**：见 P1-1。
- **三语 i18n 双层**（`zh` / `zht` / `en`）：静态 `data-i18n` 替换 + 动态 `T('key')`，且明确"教材正文与画布标注保持简体原文"——教学定位清晰。
- **全局唯一** `escHtml()`：已主动收敛过三份重复实现（L2958），方向正确，只是调用面没铺满（见 P1-3）。
- **实验模块 IIFE 隔离**：11 个模块统一 `MODULES.xxx = (function(){…})()`，只暴露 `setTheme` / `render`，`window` 上只导出 `AI` 一个。
- **版本号单一来源**：全文只有 `BUILD = 'v6.4.26'`（L20），未发现旧版本号残留；`node --check` 16/16 通过。

06 P2 / P3 · 低成本清理

级别	问题	建议
P2-1	**全局作用域名污染**：主脚本（L2145 起）**没有 IIFE 包裹**，顶层 201 个 `function` 声明直接成为 `window` 属性（`T` / `E` / `render` / `play` / `stop` / `ray` / `pair` / `val` / `save` …）	用一层 IIFE 包住主脚本，或把工具函数挂到单一命名空间 `window.OPT = {}`
P2-2	**console 噪音**：全文件 664 处 `console.*`，其中应用层 `log/debug` 25 处	交付版保留 `warn/error`，清掉 `log/debug`
P2-3	**版本注释堆积**：122 处历史注释，`V6.2.1` 出现 26 次、`V5.1.0` 19 次、`V4.9.11` 18 次	与"更新日志精简"的既定偏好一致：把"改了什么"迁到 `工作记录`，正文只留"为什么这么写"
P2-4	**风格断层**：`var` 228 处 vs `const/let` 689+ 处；箭头函数 462、模板字符串 212	V4 之前用 `var`、V6 用 `let/const`。不影响运行，只需新代码统一
P2-5	**交付目录卫生**：工作目录含 **100+ 个 `_` 前缀临时文件**、多个 `v6.4.17` 重复副本、`_废弃_坏版/` 目录	提交前归档到 `_archive/`，根目录只留最终 `.html` + 工作记录 + 审计报告，避免误交
P3-1	**注释与实现不符**：L4226 写"11 段音频 体积 ~4.18 MB"，实测解码 **2.40 MB**	修正注释，避免后续按错误数字做体积预算

P3-2	**可删的兼容别名**：L2970 `function kmapEsc(s){ return escHtml(s); }`，注释自述"保留以免遗漏调用点"	全量替换后删除，减少一层无意义跳转

07 修复路线图

v6.4.27 · 消肿与去漂移（P0）

- 确定唯一 three.js 构建，重出 6 个子页，加 `THREE_BUILD` 断言 → P0-1
- 五份重复库合并共享（父页 1 份 + blob URL）→ P0-2，预期 −1.08 MB
- 修正 L11538 / L4226 两处失真注释 → P3-1
- 交付目录归档清理 → P2-5

v6.5 · 技术债清账（P1）

- 62 处空 catch 加 `console.warn` → P1-2
- innerHTML 拼装点全量过 `escHtml`（先查判卷回显 + 诊断报告）→ P1-3
- 移除 `runE2E` 或改为显式开关 → P1-4
- postMessage 接收端改校验 `e.source` → P1-5
- 子页 iframe 加 `sandbox` → P1-6
- blob URL 回收 + 监听器改 `AbortController` → P1-7
- 音频降码率（音质对比后定档）→ 体积二次优化

v6.6 · 可维护性

- 主脚本 IIFE 包裹 → P2-1
- console 清理 → P2-2；注释瘦身 → P2-3

08 附录 · 审查指标汇总

指标	值	评价
文件体积 / 行数	8.37 MB / 11,902 行	偏大
`<script>` 块	16	结构清晰
`node --check`	16 / 16 通过	无语法错误
裸 `</script>` 提前截断	0	转义正确
硬编码 API Key / Bearer	0	无泄露
`eval()` / `document.write()`	0 / 0	干净
`new Function()`	18	均在压缩库内
`innerHTML =`	102	需补 escHtml
空 `catch(e){}`	62	静默吞异常
add / removeEventListener	137 : 0	不对称
localStorage 键	5 个	前缀统一
版本号单一来源	BUILD = v6.4.26	无旧号残留
重复函数名	385	绝大多数来自压缩库
兜底机制	V4.9.1 + 15s	优秀